

PENETRATION TESTING REPORT

VulnHub Machine: Empire — Breakout

Boot-to-Root Capture-The-Flag Exercise

Target IP Address: 10.124.239.226

Assessment Platform: VulnHub (Empire: Breakout)

Attacking Host: Kali Linux

Engagement Date: 03 September 2026

Classification: Personal Training Lab — Not for Distribution

1. Executive Summary

This report documents a self-directed penetration testing exercise performed against "Empire: Breakout", a deliberately vulnerable Linux machine hosted on VulnHub and rated as an Easy-difficulty boot-to-root challenge. The objective of the exercise was to identify an initial foothold on the host and retrieve the user-level flag, using only information gathered through standard reconnaissance and enumeration techniques.

The engagement followed a structured methodology: network and service discovery, web and SMB enumeration, credential recovery from an intentionally hidden artifact, and authenticated access to a web-based administration console. The chain of issues below allowed a foothold to be obtained without any brute forcing, memory corruption, or custom exploit development — every step relied on information the target itself disclosed.

At a high level, the compromise path was:

- A web server on port 80 disclosed an encoded credential inside an HTML comment.
- The credential was encoded using the Brainfuck esoteric language rather than genuine encryption, and was decoded with a public interpreter.
- SMB enumeration (enum4linux) revealed a valid local username, 'cyber', with no authentication required.
- The recovered password was valid for the 'cyber' account on the Usermin web-administration panel (TCP/20000), granting an authenticated session and terminal (console) access.
- From the Usermin console, the user-flag file (user.txt) was located and read, completing the user-level objective of the exercise.

This report presents the methodology, evidence, and analysis for each stage, followed by a consolidated findings table and remediation guidance that would apply to a real-world deployment exhibiting the same weaknesses.

2. Scope and Objectives

The scope of this exercise was limited to a single isolated virtual machine ('Empire: Breakout') running on a private lab network, with no external parties or production systems involved. The engagement was conducted for personal skills development and is documented here purely for learning and portfolio purposes.

2.1 Objectives

- Enumerate all network services exposed by the target.
- Identify and exploit any information disclosure or misconfiguration that could lead to valid credentials.
- Gain an authenticated foothold on the target and retrieve the user flag.

2.2 Rules of Engagement

- Testing was restricted to the single target IP address 10.124.239.226 within an isolated lab network.
- No denial-of-service or destructive techniques were used.
- All activity was performed from a Kali Linux attack host under the operator's own control.

3. Methodology and Tooling

The assessment followed a conventional four-phase methodology common to CTF and real-world penetration tests: reconnaissance, enumeration, exploitation/initial access, and post-exploitation. The following tools were used:

- Nmap — port and service/version scanning.
- Dirb — directory and file brute forcing over HTTP.
- Web browser (view-source) — manual inspection of client-side content.
- dCode Brainfuck Interpreter — decoding of an esoteric-language cipher.
- enum4linux — SMB/NetBIOS enumeration of users, shares, and policy.
- Usermin (target's own web console) — authenticated command execution once credentials were obtained.

4. Reconnaissance

An initial full-port TCP scan with service/version detection was run against the target to build a complete picture of the attack surface before narrowing focus.

```
nmap -p- -sV 10.124.239.226
```

```
(root@kali)-[/home/kali]
# nmap -p- -sV 10.124.239.226
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 13:05 +0530
Nmap scan report for 10.124.239.226
Host is up (0.00037s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Apache httpd 2.4.51 ((Debian))
139/tcp   open  netbios-ssn    Samba smbd 4
445/tcp   open  netbios-ssn    Samba smbd 4
10000/tcp open  http           MiniServ 1.981 (Webmin httpd)
20000/tcp open  http           MiniServ 1.830 (Webmin httpd)
MAC Address: 08:00:27:E9:2B:9F (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 48.99 seconds
```

Figure 1 – Full TCP port scan showing Apache (80), Samba (139/445), and Webmin/Usermin (10000/20000).

The scan returned five open ports of interest: TCP/80 (Apache httpd 2.4.51), TCP/139 and TCP/445 (Samba smbd 4), and two instances of MiniServ — the engine behind Webmin (10000) and Usermin (20000). The presence of two separate web-based administration consoles alongside a standard web server and SMB immediately suggested that credential recovery, rather than a memory-corruption exploit, would be the most likely route to a foothold — a hypothesis that shaped the rest of the enumeration phase.

5. Enumeration

5.1 Web Content Discovery

With port 80 confirmed open, a directory brute-force scan was run to check for hidden paths beyond the default Apache page.

```
dirb http://10.124.239.226/
```

```
(root@kali)-[/home/kali]
# dirb http://10.124.239.226/

DIRB v2.22
By The Dark Raver

START_TIME: Thu Sep  3 13:16:07 2026
URL_BASE: http://10.124.239.226/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://10.124.239.226/ ---
+ http://10.124.239.226/index.html (CODE:200|SIZE:11159)
=> DIRECTORY: http://10.124.239.226/manual/
+ http://10.124.239.226/server-status (CODE:403|SIZE:279)

--- Entering directory: http://10.124.239.226/manual/ ---
=> DIRECTORY: http://10.124.239.226/manual/da/
=> DIRECTORY: http://10.124.239.226/manual/de/
=> DIRECTORY: http://10.124.239.226/manual/en/
=> DIRECTORY: http://10.124.239.226/manual/es/
=> DIRECTORY: http://10.124.239.226/manual/fr/
```

Figure 2 – Dirb scan of the web root; only the default Apache 'manual' directory was discoverable.

The scan surfaced nothing beyond Apache's own bundled manual and a forbidden server-status endpoint, indicating that the two Webmin-family ports were more likely to hold the real path forward than the website itself. Direct requests to the web roots of ports 10000 and 20000 were also attempted and returned generic 404 responses, confirming that no static content was being served on either administration port and that any information would need to come from elsewhere on the host.

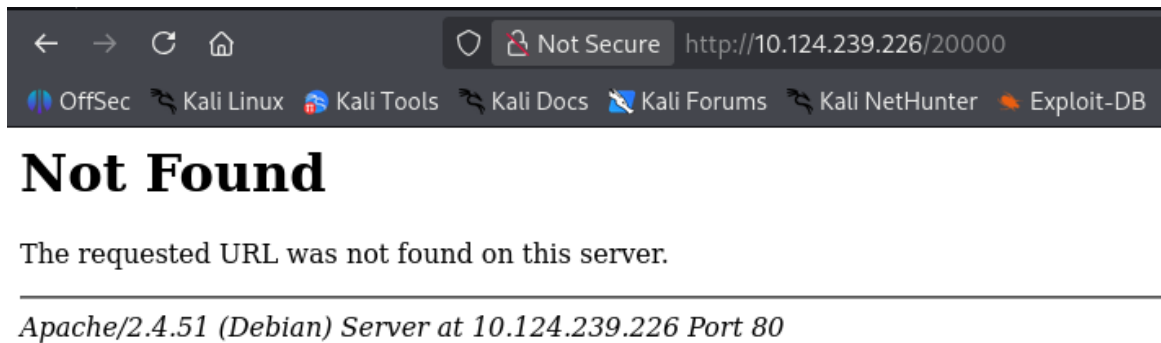


Figure 3 – Direct request to port 20000 root returns a generic Apache 404, ruling out static web content on that port.

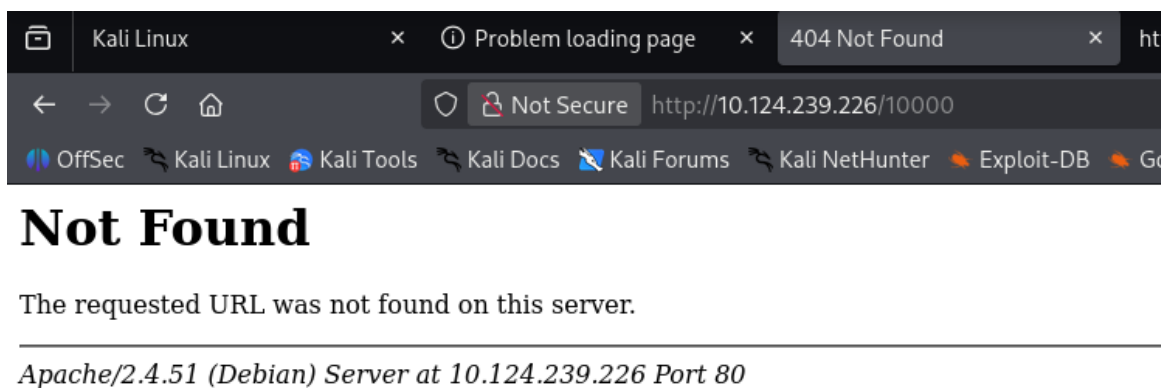


Figure 4 – The same behaviour on port 10000, confirming both MiniServ instances serve no public web content.

5.2 Source Code Disclosure

Because the web root itself offered nothing of interest, the page's HTML source was inspected manually rather than relying on automated tools — a step that automated scanners frequently miss because the content is only visible inside an HTML comment, not in the rendered page. This revealed a comment left by the machine's author containing what was described as an 'encrypted' credential.

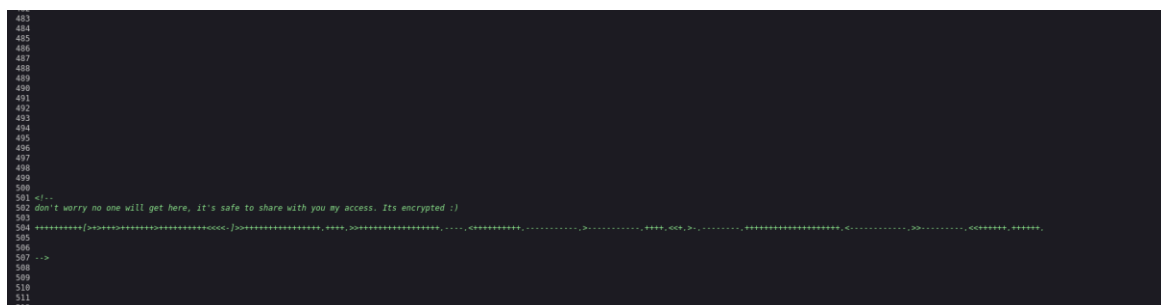


Figure 5 – HTML source of the default Apache page containing a hidden comment with an encoded credential string.

The character set used in the hidden string — long runs of plus/minus signs, angle brackets, and periods — is a strong visual fingerprint for Brainfuck, an esoteric programming language sometimes (mis)used as

a lightweight obfuscation scheme. Despite the comment's claim that the data was 'encrypted', Brainfuck code is fully reversible with any public interpreter and provides no real confidentiality — an important distinction between obfuscation and encryption that is explored further in the Findings section.

5.3 Decoding the Recovered Cipher

The Brainfuck payload was passed to a public online interpreter to recover the underlying plaintext.



Figure 6 – The Brainfuck string decoded via the dCode online interpreter, revealing a plaintext credential.

The interpreter returned the plaintext string `.2uqPEfj3D<P'a-3`, which was saved locally for reuse against the services identified during reconnaissance.

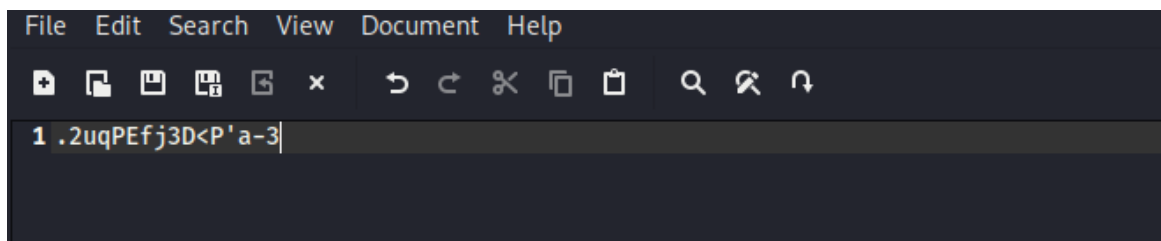


Figure 7 – Decoded credential saved for use in the next stage of the assessment.

5.4 SMB / NetBIOS Enumeration

With a candidate password in hand but no confirmed username, SMB (ports 139/445) was targeted next, since it is one of the few services on the host that commonly discloses account names without authentication.

```
enum4linux -a 10.124.239.226
```

```
(root@kali)-[/home/kali]
# enum4linux -a 10.124.239.226
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu Sep  3 13:45:28 2026

===== ( Target Information ) =====

Target ..... 10.124.239.226
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

Figure 8 – enum4linux launched against the target with full (-a) enumeration.

The scan enumerated a local (non-domain) SID and resolved it to a real operating-system account, cyber, without requiring any credentials — a classic SMB null-session information disclosure. This gave the second half of the credential pair needed to attempt authentication elsewhere on the host.

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''
S-1-22-1-1000 Unix User\cyber (Local User)

[+] Enumerating users using SID S-1-5-21-1683874020-4104641535-3793993001 and logon
S-1-5-21-1683874020-4104641535-3793993001-501 BREAKOUT\nobody (Local User)
S-1-5-21-1683874020-4104641535-3793993001-513 BREAKOUT\None (Domain Group)
```

Figure 9 – enum4linux resolving SID S-1-22-1-1000 to the local account 'Unix User\\cyber'.

6. Initial Access

With a username (cyber) and a password (.2uqPEfj3D<P'a-3) in hand, the two MiniServ-based panels identified during reconnaissance were the logical next target. Usermin, on TCP/20000, is designed to let a standard (non-root) account manage its own mail, cron jobs, and — significantly — open a command-line console, making it a realistic path from disclosed credentials to code execution.

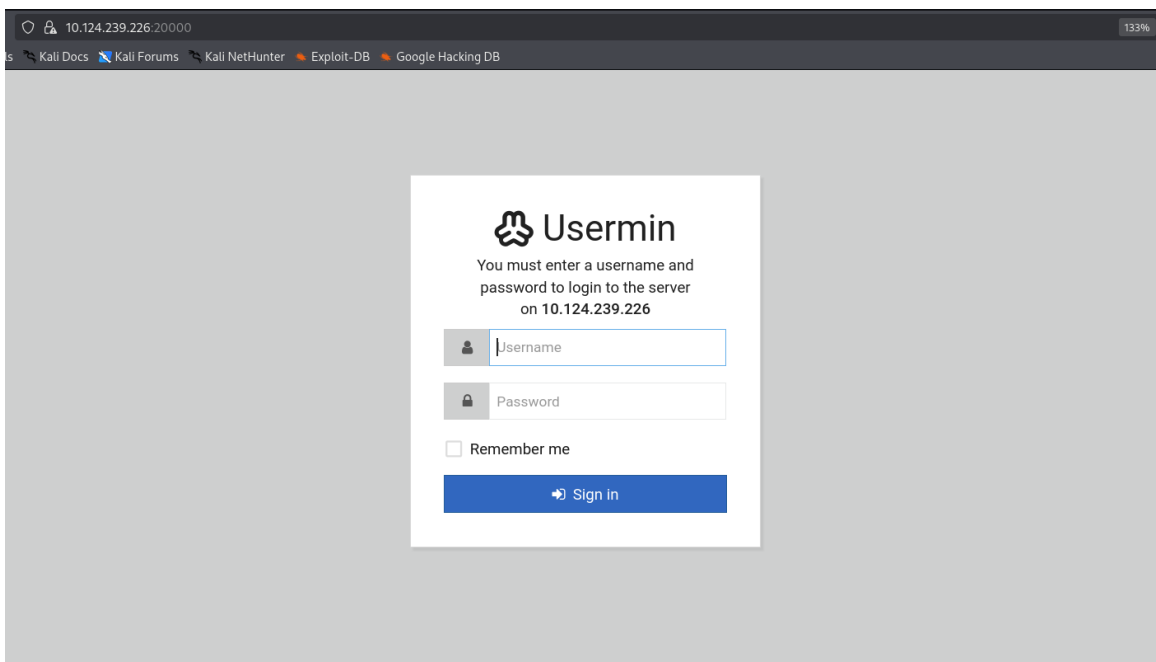


Figure 10 – Usermin login prompt served on TCP/20000.

The recovered credentials were submitted directly against this login form.

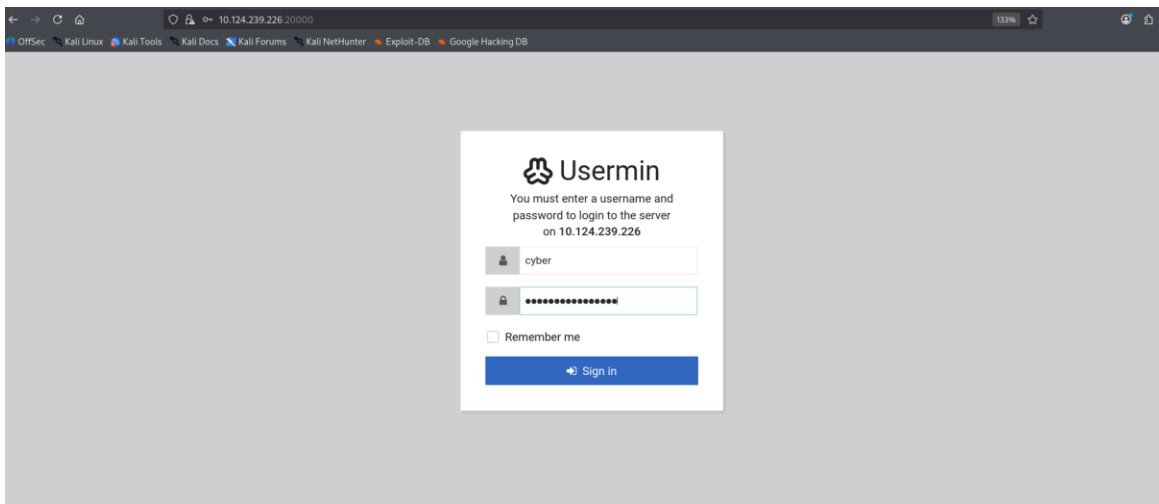


Figure 11 – Authenticating to Usermin as 'cyber' using the decoded password.

Authentication succeeded on the first attempt, confirming both password reuse across services and the validity of the enumerated username, and returning a full Usermin session (mail, address book, and account-management modules) for the cyber account.

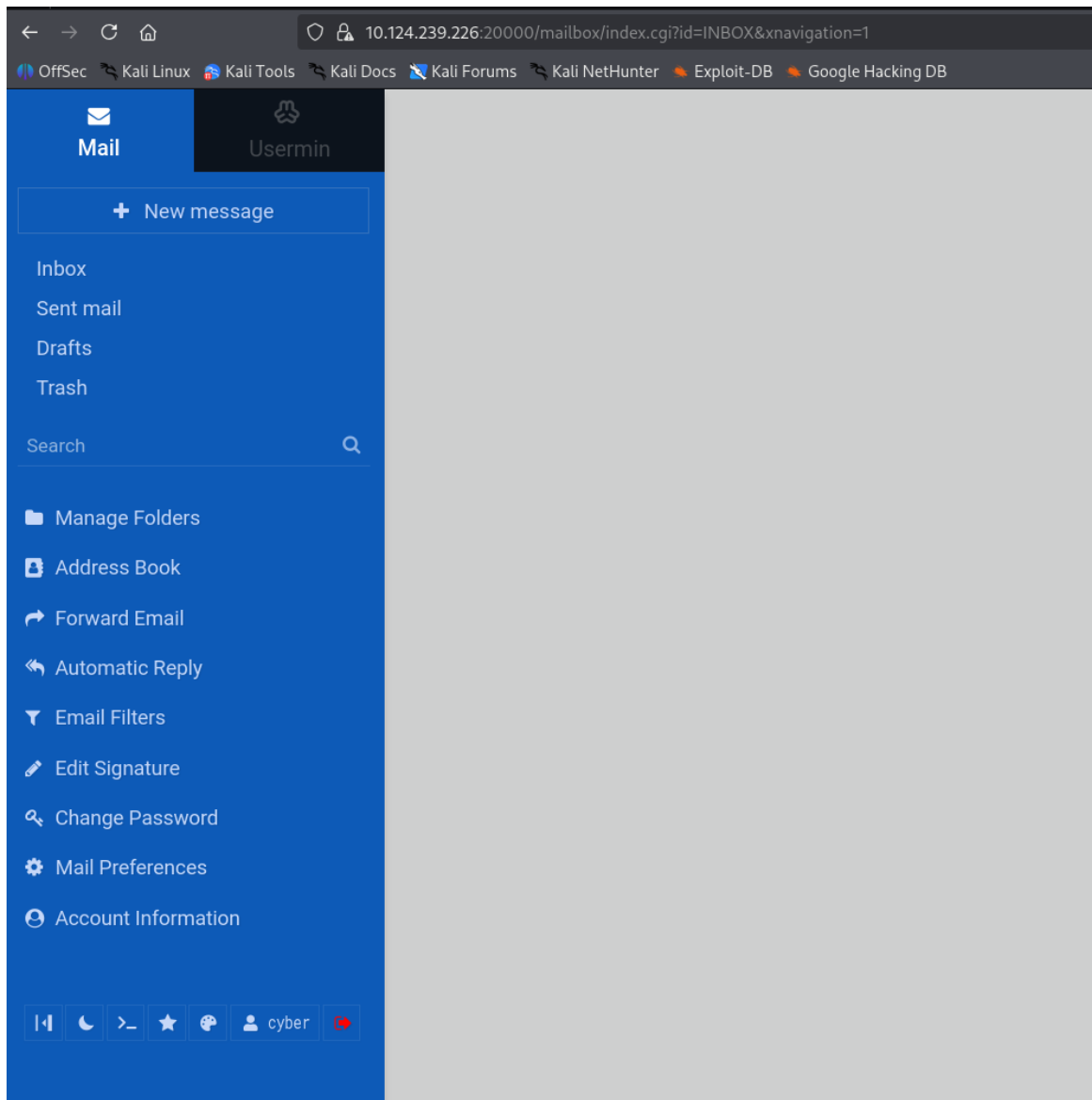


Figure 12 – Successful authenticated Usermin session for the 'cyber' account.

7. Post-Exploitation and Flag Capture

Usermin exposes a built-in terminal console module to authenticated users, which was used in place of a separate reverse shell to interact with the underlying operating system directly as the cyber account.

```
[cyber@breakout ~]$ ls
tar
user.txt
[cyber@breakout ~]$ |
```

Figure 13 – Interactive console access as 'cyber', showing the home directory contents: a tar binary and user.txt.

The user's home directory contained two items of note: a locally-owned copy of the tar binary (a detail that — outside the scope of what this exercise captured — is normally the pivot point for privilege escalation on this machine via Linux capabilities) and the target user.txt flag file. The flag file was read directly from the console:

```
cat user.txt
```

```
[cyber@breakout ~]$ ls
tar
user.txt
[cyber@breakout ~]$ cat user.txt
3mp!r3{You_Manage_To_Break_To_My_Secure_Access}
[cyber@breakout ~]$ |
```

Figure 14 – Contents of user.txt, confirming successful compromise of the 'cyber' account.

The retrieved flag, 3mp!r3{You_Manage_To_Break_To_My_Secure_Access}, confirms full compromise of the standard user account and satisfies the user-level objective of this exercise. The presence of a capability-enabled tar binary in the same directory indicates a clear next step toward root — outside the scope of the evidence captured in this write-up, but noted here for completeness.

8. Findings Summary

The table below consolidates the distinct weaknesses that combined to produce the compromise path documented in this report.

ID	Finding	Risk	Description
----	---------	------	-------------

F-1	Information disclosure via HTML source comment	Medium	Encoded credentials for an internal account were embedded in an HTML comment on the public Apache default page.
F-2	Weak obfuscation mistaken for encryption	Medium	The hidden credential was encoded with Brainfuck, a reversible esoteric-language cipher, not real encryption. It was decoded in seconds with a public online interpreter.
F-3	SMB null-session user enumeration	Medium	enum4linux enumerated a valid local account name ('cyber') from SMB (ports 139/445) without any credentials, enabling a targeted credential-stuffing attempt.
F-4	Exposed, internet-facing administration panel (Usermin)	High	Usermin (port 20000) was reachable directly and accepted the recovered credentials, providing an authenticated web shell/console to the account.
F-5	Password reuse enabling full account takeover	High	The single decoded credential was valid for both the discovered SMB username and the Usermin web login, giving a direct path from a cosmetic hint to a working shell and the user flag.

9. Recommendations

The following recommendations reflect what would be advised to a system owner running a real deployment with the characteristics observed on this lab machine. They are provided for learning purposes, since the target itself is an intentionally vulnerable training image.

Recommendation	Rationale
Remove sensitive data from client-visible source	Never leave credentials, hints, or internal notes in HTML/JS comments, even 'encoded'. Treat anything shipped to the browser as public.
Do not rely on obfuscation as a security control	Replace encoding tricks (Base64, Brainfuck, ROT13, etc.) with real secrets management (vault, environment variables, secret managers) and enforce credential rotation.
Harden SMB against anonymous enumeration	Disable null sessions ('restrict anonymous' / 'map to guest = never'), and remove unused SMB shares/services on hosts that do not need them.
Restrict exposure of admin interfaces	Usermin/Webmin (ports 10000/20000) should sit behind a VPN, bastion host, or IP allow-list — never exposed to the same network segment as end users.
Patch and version-lock management software	Usermin/Webmin should be kept current; the version identified during this engagement is affected by known CVEs (e.g. CVE-2019-15107) that were not required for this compromise but represent additional risk.
Enforce unique credentials per service	The same password should not grant both SMB and web-panel access. Use per-service credentials and a password manager or vault.

10. Conclusion

This exercise reinforced that the majority of real-world compromises begin with information disclosure and credential reuse rather than sophisticated exploit development. Every step required to reach the user flag on Empire: Breakout — reading an HTML comment, decoding a well-known esoteric cipher, running an unauthenticated SMB enumeration tool, and reusing a single recovered password against an exposed administration panel — relied on functionality the target exposed by default or through a simple misconfiguration.

From a learning perspective, the machine provided practical, hands-on reinforcement of manual source-code review, the distinction between obfuscation and true encryption, SMB null-session enumeration, and the risk of running internet-facing administrative interfaces such as Usermin/Webmin without additional access controls. These are patterns directly transferable to real infrastructure assessments.

Overall, the objectives of the exercise were met: a foothold was established on the target and the user flag was successfully retrieved and validated.